

Executive Summary:

APT40 is a cyberespionage threat group linked to the Chinese government, known for targeting critical technologies and traditional intelligence firms in North America, Europe, and East Asia. The group is conducting cyber operations since at least 2013, and its espionage activities mostly support China's naval modernization attempt. This cyberespionage group was previously reported as TEMP.Periscope and TEMP.Jumper. Most recently, in early-2019, it was again seen attempting to steal secrets related to advanced technology to support the development of Chinese naval capabilities.

Since 2013, the group has targeted engineering, transportation, defense, and maritime sectors, aligning with China's geopolitical interests, including the Belt and Road Initiative and South China Sea disputes. It seeks to acquire advanced naval technology and support China's maritime expansion by targeting key countries and marine research institutions, especially in the U.S.

It exploits different vulnerabilities such as : CVE-2017-0199, CVE-2012-0158, CVE-2017-11882, and CVE-2017-875

Here we are talking about a particular vulnerability CVE-2017-0199 which was exploited using a payload, it was a Rich Text Format file of 129.49KB which was first seen in 2017-08-11.

Its File hash is:

SHA-1 bf8a297b4a1fd8ee1666be74afca80a8addb145d

SHA-256 6f6ee01e9dc2d8c4c260ef4131fe88dc152e53ee8afd3e66e92d4e1bf5fd2e92

And it was related to Domain:

thyssenkrupp-marinesystems.org

www.thyssenkrupp-marinesystems.org

With Subdomain:

media4football.thyssenkrupp-marinesystems.org 89.245.139.187

elara.thyssenkrupp-marinesystems.org 89.245.139.187

s3.thyssenkrupp-marinesystems.org 89.245.139.187

nqw.thyssenkrupp-marinesystems.org 89.245.139.187

webmail.thyssenkrupp-marinesystems.org 89.245.139.187

wwwca.thyssenkrupp-marinesystems.org 89.245.139.187

freewww.thyssenkrupp-marinesystems.org 89.245.139.187

httpwww.thyssenkrupp-marinesystems.org 89.245.139.187

shop.thyssenkrupp-marinesystems.org 89.245.139.187

thyssenkrupp-marinesystems.org 89.245.139.187

www.thyssenkrupp-marinesystems.org 89.245.139.187

And the Possible C2s is:

89.245.139.187

Key IOCs :

Files communicated using this Ip:

- 0842f8f1a37667e73d59b2e62d7249f00c5d9937bae5a101c72e46f73daaa917
- 42538f3ee9496ed3e9de1153f9eb793daa56af7ee608b05460ee497f0c467ac1
- 7f01995d50b15ae9bd7ec6e251876d557cca48ca49513a36a5a2f211055df99f
- C82ec4210eee83de57e1e319a3fd43a1a915adb87e4307b3fd58d18417fb7ac2
- Fb77d27115935d47c803c77b3506ec2c796f8b9019af3e04f77b88cba650cadf

Files Referring

- 2f6cb885-2512-498c-b903-66a9016bcb0e
- 49c38825-bb1b-490c-9bd7-6347152d277d
- 058c6b8f-db5b-4aa4-9f10-8ca73742cba3

Contacted IP addresses

- 114.114.114.114
- 89.245.139.187
- 8.8.8.8
- 224.0.0.252

Methodology

Tools used For subdomain finding:

Sublist3r

Subfinder

CRT.sh

Tools used For finding NS Records:

DNSDumpster

Whois Lookup

Tools used For information and logs gathering:

Virustotal

Tor

OSINT platforms:

WHOIS records

[0x00sec - The Home of the Hacker](#)

[Chinese Threat Actor TEMP.Periscope Targets UK-Based Engineering Company Using Russian APT Techniques](#)

[| Recorded Future](#)

Tactics, Techniques, and Procedures of Indicted APT40 Actors Associated with China's MSS
Hainan State Security Department | CISA
APT40: A State-Sponsored Cyber Espionage Group Targeting North America And Europe to
Obtain Advanced Naval Technology | Cyware

Dark web forums:

<http://forums56xf3ix34sooaio4x5n275h4i7ktliy4yphhxohuemjppgovrad.onion/>
<http://hellhoh5o35sylvxrpfu45p5r74n2lzvirnvshmziuvn7bcejlynaqxyd.onion/>

Detailed Analysis:

Subdomain and IP discoveries, port/service details.

media4football.thyssenkrupp-marinesystems.org	89.245.139.187
elara.thyssenkrupp-marinesystems.org	89.245.139.187
s3.thyssenkrupp-marinesystems.org	89.245.139.187
nqw.thyssenkrupp-marinesystems.org	89.245.139.187
webmail.thyssenkrupp-marinesystems.org	89.245.139.187
wwwca.thyssenkrupp-marinesystems.org	89.245.139.187
freewww.thyssenkrupp-marinesystems.org	89.245.139.187
httpwww.thyssenkrupp-marinesystems.org	89.245.139.187
shop.thyssenkrupp-marinesystems.org	89.245.139.187
thyssenkrupp-marinesystems.org	89.245.139.187
www.thyssenkrupp-marinesystems.org	89.245.139.187

Name Servers

NS.INWX.DE

NS2.INWX.DE

NS3.INWX.EU

Network Communication

HTTP requests

GET http://www.thyssenkrupp-marinesystems.org:80/templater.doc

GET http://www.thyssenkrupp-marinesystems.org/templater.doc

DNS Resolutions

www.thyssenkrupp-marinesystems.org

IP Traffic

TCP 89.245.139.187:80 (www.thyssenkrupp-marinesystems.org)

TCP 224.0.0.252:5355

TCP 8.8.8.8:53

TCP 114.114.114.114:53

89.245.139.187:80 (www.thyssenkrupp-marinesystems.org)

Evidence of malicious behavior or C2 hosting.

6f6ee01e9dc2d8c4c260ef4131fe88dc152e53ee8afd3e66e92d4e1bf5fd2e92

Zudar

44

/ 62

Community Score

-1

44/62 security vendors flagged this file as malicious

Reanalyze Similar More

6f6ee01e9dc2d8c4c260ef4131fe88dc152e53ee8afd3e66e92d4e1bf5fd2e92

Size129.49 KBLast Analysis Date7 months agoRTF

ODNI.rtf

rtf cve-2017-0199 ole-autolink exploit cve-2019-0199

DETECTION

DETAILS

RELATIONS

BEHAVIOR

COMMUNITY15

Contacted URLs (1)

Scanned	Detections	Status	URL
2023-06-30	8 / 90	-	http://www.thyssenkrupp-marinesystems.org/templater.doc

Contacted Domains (2)

Domain	Detections	Created	Registrar
thyssenkrupp-marinesystems.org	10 / 94	2017-04-25	INWX GmbH
www.thyssenkrupp-marinesystems.org	10 / 94	2017-04-25	INWX GmbH

Historic Targeting of U.K. Engineering Company by TEMP.Periscope

Prior to this attempt in July, the same U.K. engineering company had previously been targeted in May 2017. This campaign used the ETERNALBLUE exploit and a unique DNS tunneler backdoor. The DNS tunneler used in the attack was configured to communicate with a subdomain of thyssenkrupp-marinesystems[.]org. The domain was clearly spoofing German defense contractor ThyssenKrupp Marine Systems, which specializes in marine engineering. In addition to hosting the spoofed domain, Netherlands-based HostSailor VPS IP 185.106.120[.]206 also hosted an open directory containing malware and tools for use by the threat actor, not dissimilar to the TEMP.Periscope scsnewstoday[.]com C2 and open directory set up.

10

/ 94

Community Score

⚠️ 10/94 security vendors flagged this domain as malicious

↻ Reanalyze ⌵ Similar ⌵ More ⌵

thyssenkrupp-marinesystems.org

Registrar
INWX GmbH

Creation Date
7 years ago

Last Analysis Date
12 days ago

Malicious (alphaMountain.ai)

top-1M

DETECTION

DETAILS

RELATIONS

COMMUNITY 6

Security vendors' analysis ⓘ

Do you want to automate checks?

alphaMountain.ai	⚠️ Malicious	CyRadar	⚠️ Malicious
ESET	⚠️ Malware	Fortinet	⚠️ Malware
Kaspersky	⚠️ Malware	Lionic	⚠️ Malicious
Seclookup	⚠️ Malicious	SOCRadar	⚠️ Malware
Sophos	⚠️ Malware	Webroot	⚠️ Malicious

Attribution & TTPs

Persistence (TA0003)

Event Triggered Execution (T1546)

Change Default File Association (T1546.001)

Privilege Escalation (TA0004)

Event Triggered Execution (T1546)

Change Default File Association (T1546.001)

Defense Evasion (TA0005)

Masquerading (T1036)

Conclusion & Recommendations:

APT40 is a well-known Chinese state-sponsored hacking group focused on cyber espionage, mainly targeting government, defense, and maritime industries. Their methods include credential theft, supply chain attacks, and custom malware, making them a persistent threat. Organizations need to stay proactive with strong cybersecurity measures to defend against their tactics.

To defend against APT40, organizations should:

Block Malicious Infrastructure: Use threat intelligence to block APT40-associated domains and IPs.

Enforce Zero Trust: Restrict network movement and verify user access rigorously.

Enable MFA: Reduce risks from credential theft.

Segment Networks: Isolate critical systems to limit damage from intrusions.

Patch Regularly: Address vulnerabilities exploited by APT40.

Deploy SIEM & Threat Detection: Use behavioral monitoring to detect anomalies.

Use Honeypots: Gather intelligence on APT40 tactics through deception techniques.

To stay ahead of APT40's evolving tactics, security teams should:

Monitor OSINT & Dark Web: Track discussions on APT40's latest exploits and tactics.

Analyze Infrastructure: Use passive DNS monitoring to detect new C2 servers.

Join Threat Intelligence Networks: Collaborate with ISACs and cybersecurity organizations.

Reverse Engineer Malware: Study APT40-linked malware to uncover new attack strategies.

Appendices:

Threat Actor Profile

Origin : 2013

Aliases : Leviathan, TEMP.Jumper, TEMP.Periscope, APT 40

Key Target Sectors : Transportation, Government / Military, Educational, InformationTechnology, Communication, Manufacturing, Enterprise Services

Attack Vectors : Spam Email, Spear phishing, Phishing, and Luring.

Target Region : Western Europe, North America, South-East Asia

Malware Used : ScanBox, WindTone, Grillmark, BlackCoffee, Gh0st, China Chopper, WilDelk, FreshAir, KorPlug, HomeFry, RedMage, FieldGoal, RedMage, AirBreak, Js Spy, Murkytop, Beacon, MurkysheIl, Orz, LunchMoney, and NanHaiShu.

Tools Used : PaperRush, Photo

Vulnerabilities Exploited : CVE-2017-0199, CVE-2012-0158, CVE-2017-11882, and CVE-2017-8759

Attack Lifecycle

Initial Compromise

APT40 has been observed leveraging a variety of techniques for initial compromise, including web server exploitation, phishing campaigns delivering publicly available and custom backdoors, and strategic web compromises.

- APT40 relies heavily on web shells for an initial foothold into an organization. Depending on placement, a web shell can provide continued access to victims' environments, re-infect victim systems, and facilitate lateral movement.
- The operation's spear-phishing emails typically leverage malicious attachments, although Google Drive links have also been observed.
- APT40 leverages exploits in their phishing operations, often weaponizing vulnerabilities within days of their disclosure. Observed vulnerabilities include:
 - CVE-2012-0158
 - CVE-2017-0199
 - CVE-2017-8759
 - CVE-2017-11882

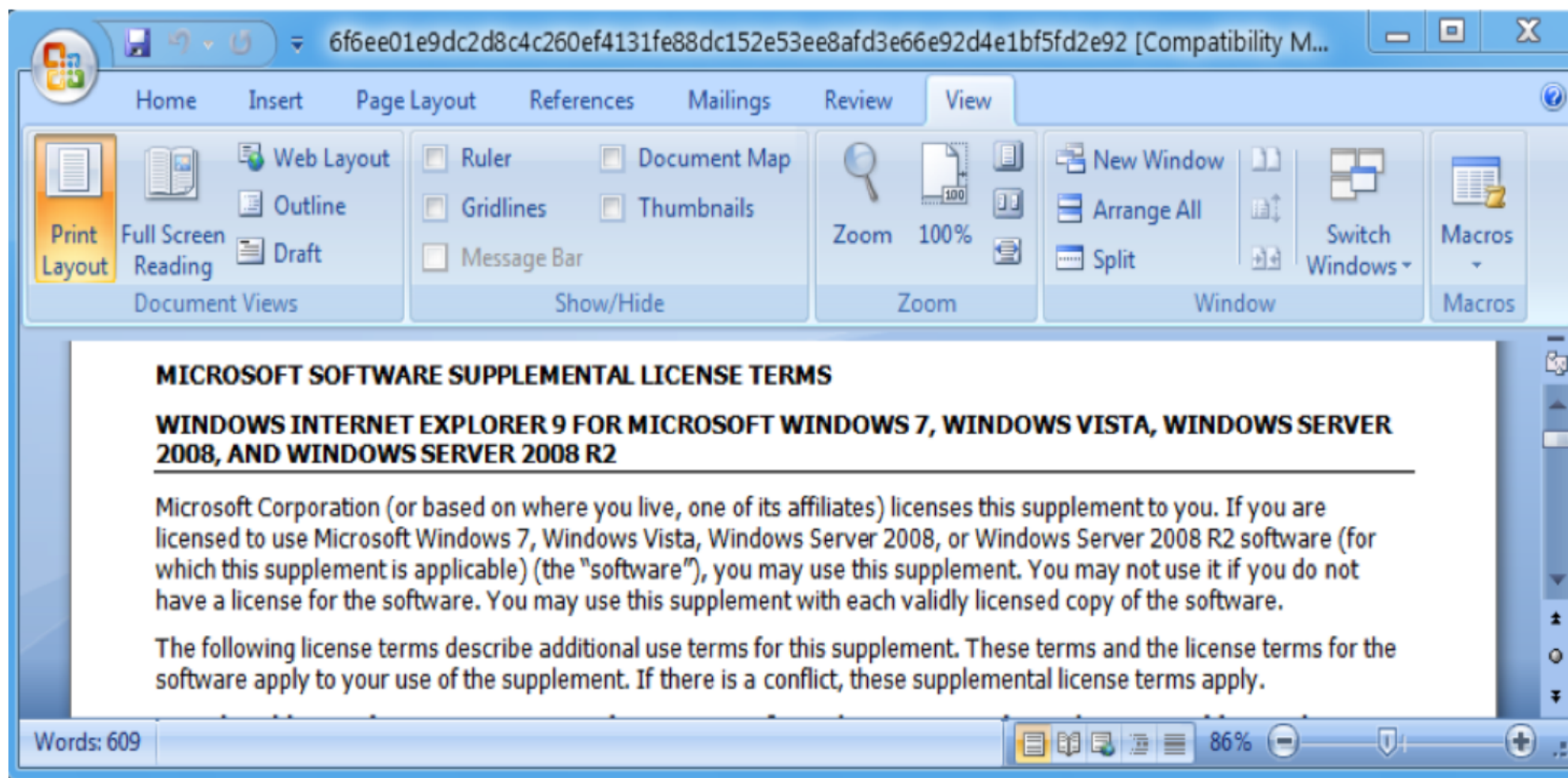


Figure 2: One of the documents involved in the campaign used Microsoft licensing lures purporting to be from a well-known shipbuilder (sha256: 6f6ee01e9dc2d8c4c260ef4131fe88dc152e53ee8afd3e66e92d4e1bf5fd2e92).

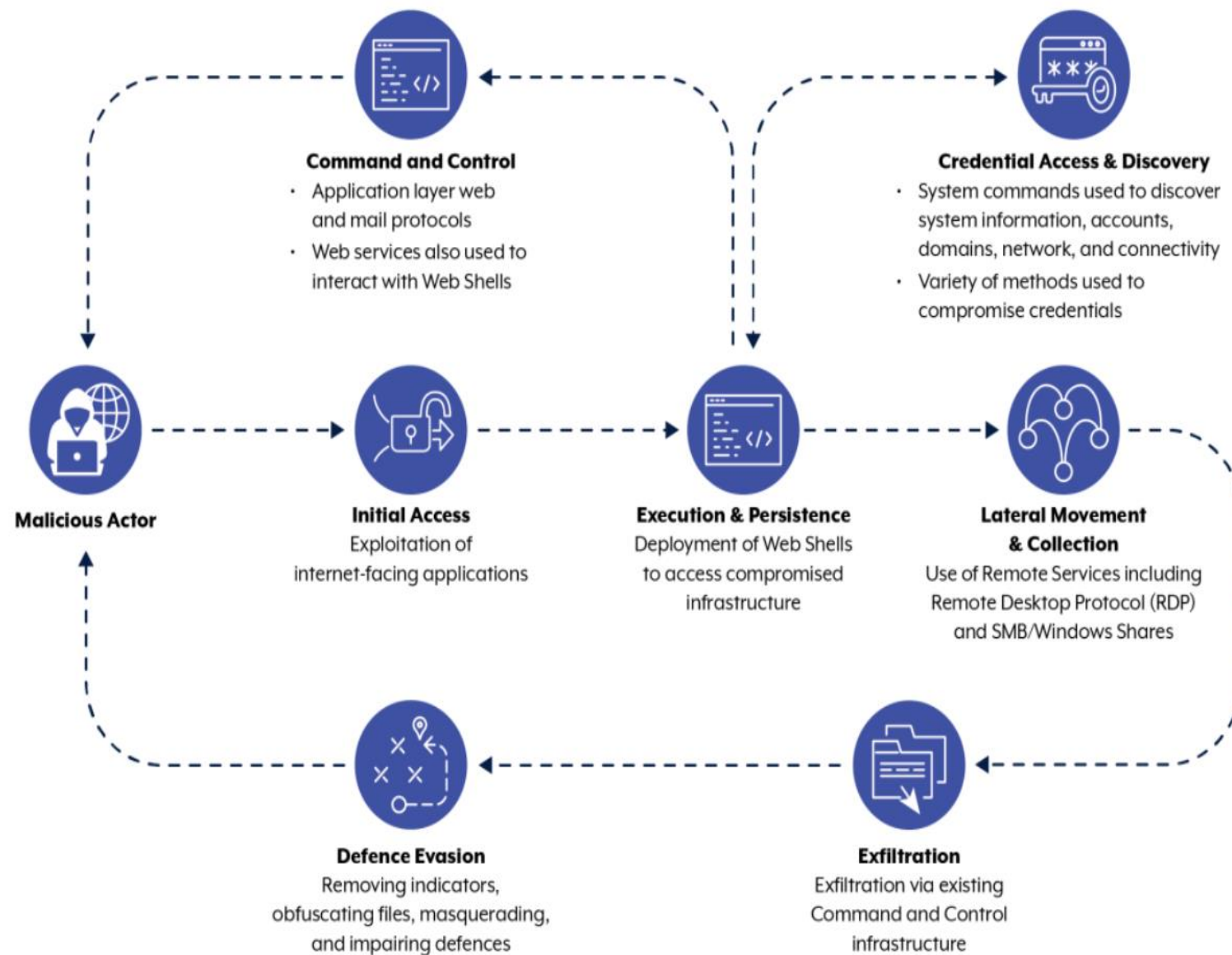


Figure 1: TTP Flowchart for APT40 activity



Criteria	Type: Identity Match: ILIKE Search: 'thyssenkrupp-marinesystems.org'
----------	--

Certificates	crt.sh ID	Logged At ↑	Not Before	Not After	Common Name	Matching Identities	Issuer Name
	304208028	2018-01-15	2017-04-26	2018-04-26	thyssenkrupp-marinesystems.org	thyssenkrupp-marinesystems.org www.thyssenkrupp-marinesystems.org	C=GB, ST=Greater Manchester, L=Salford, O=COMODO CA Limited, CN=COMODO RSA Domain Validation Secure Server CA

Whois Record for ThyssenKrup...Systems.org

— Domain Profile

Registrar	INWX GmbH IANA ID: 1420 URL: http://www.domrobot.com Whois Server: https://www.inwx.de/de/domain/whois abuse@inwx.com (p) +49.3098321212
Registrar Status	clientTransferProhibited
Dates	2,878 days old Created on 2017-04-25 Expires on 2025-04-25 Updated on 2024-06-09
Name Servers	NS.INWX.DE (has 270,569 domains) NS2.INWX.DE (has 270,569 domains) NS3.INWX.EU (has 32 domains)
IP Address	89.245.139.187 is hosted on a dedicated server